Action plan

Business: Example Electrical Ltd Date: 23 October 2026

First wave by: 22 November 2026

16 measures for Example Electrical Ltd, taken from every answer that was “partly” or “not yet”. Three waves: what questionnaires and insurers ask first comes first. A measure is done when its evidence exists in the evidence folder.

Wave 1 · by 22 November 2026

No.	Measure	Today	Responsible	Evidence afterwards
1	Switch on multi-factor authentication for remote access (VPN, remote desktop), every administrator account, the cloud consoles and online banking.	Partly: VPN yes, the admin console of the cloud not yet	Owner or managing director with Example IT Services Ltd	Screenshots or administrator report per system.
2	Set up daily automatic backups of all business data with one copy out of reach of an attacker: offline, on a rotated disk, or in a cloud copy that cannot be deleted from the office.	Partly: daily to the NAS in the office, no offline copy	Owner or managing director with Example IT Services Ltd	Backup settings and schedule; where the copy out of reach is.
3	Restore one folder from the backup, stop the time, write down date, duration and result. Repeat once a year.	Not yet	Owner or managing director with Example IT Services Ltd	Restore test record with date and duration.
4	Print the emergency card of this toolkit, post it, put one copy in the drawer of the responsible person and one with the deputy at home. Check the numbers before printing.	Not yet	Owner or managing director	Emergency card, posted and dated.
5	Name who checks after an incident whether personal data is affected and who reports to the data protection authority within 72 hours of becoming aware. Put both on the emergency card.	Partly	Owner or managing director	Emergency card; the names in the rules.

Wave 2 · by 21 January 2027

No.	Measure	Today	Responsible	Evidence afterwards
6	Write the security rules for staff on one or two pages: devices, passwords, email, payments, what to report and to whom. The management signs them, every person acknowledges them.	Partly	Owner or managing director	Signed rules with date; acknowledgement list.
7	Write the list of all accounts per person and add an offboarding checklist that disables them on the day of leaving. Test it on the next departure.	Partly	Owner or managing director	Account list; offboarding checklist with dates.
8	Remove administrator rights from the daily accounts and create separate administrator accounts that are used only for administration.	Not yet	Owner or managing director with Example IT Services Ltd	Account list showing daily and administrator accounts.
9	Roll out a password manager for everyone and write the rule: one long password per account, fifteen characters or more where there is no second factor, changed only on suspicion, checked against breach lists.	Partly	Owner or managing director	Written rule; password manager rolled out (licence or screenshot).
10	Write the device list: device, user, system, supported until. Replace or take off the network every device whose system is no longer supported.	Partly: no written list; the workshop computer still runs an old system	Owner or managing director with Example IT Services Ltd	Device list with dates.
11	Update the router or firewall, change its administrator password, switch off remote administration, separate the guest network from the business network.	Partly: guest network yes, firmware and password unknown	Owner or managing director with Example IT Services Ltd	Router settings and the date of the check.
12	Start an incident log: one page per incident with what happened, how, what was missing, what was changed, who checked it.	Not yet	Owner or managing director	Incident log, even if still empty, with a date.
13	Hold a half-hour briefing on phishing, passwords, payments and the reporting channel. Keep the attendance list with date and contents. Repeat once a year and for every new hire.	Not yet	Owner or managing director	Attendance list with date and contents.
14	Write the list of providers that handle your data or your customers' data: provider, country, purpose, contract, contact.	Partly	Owner or managing director	Provider list with country and purpose.

No.	Measure	Today	Responsible	Evidence afterwards
15	Obtain the data processing agreement from every provider that processes personal data on your behalf, and switch on multi-factor authentication and set up a second administrator account for a second person in every provider console.	Partly	Owner or managing director with Example IT Services Ltd	Agreements filed; console settings.

Wave 3 · by 21 April 2027

No.	Measure	Today	Responsible	Evidence afterwards
16	Add to the rules that the customer is informed before a provider that handles their data is changed; keep a template email.	Not yet	Owner or managing director	Rule; template email.

Review

Fixed date	23 October 2027
Occasions	A new customer questionnaire; a departure or a change of contact person; a new provider; a change to the backup; an incident

Generated with the Scutoria Security Evidence Toolkit from the answers of the business. The plan is a commitment of the business to itself; the dates are its own. Password length of fifteen characters (measure C6): NIST SP 800-63B-4, July 2025, section 3.1.1.2, retrieved 19 October 2026; see the handbook, question C6. Source-based. No legal advice.